SISTEMA SIG PARA LA GESTIÓN DE INTERVENCIONES EN EL ESPACIO PÚBLICO DE SANTIAGO DE CALI

PRU-03

INFORME Y ACTA DE SEGURIDAD

SIMULACIÓN ACADÉMICA

Versión 1.0 · 25 de octubre de 2026
Ventana de referencia: 28 de junio a 2 de julio de 2027 (C)
Autora: Karol Andrea Hoyos Echandia

Ambiente lógico de referencia: QAS/UAT · Fase F3

Control del documento

Campo	Contenido
Código	PRU-03_Informe-Seguridad_v1.0
Versión / fecha	1.0 / 25 de octubre de 2026
Estado	Informe y acta de resultados simulados; verificación institucional y aprobación formal pendientes.
Autora	Karol Andrea Hoyos Echandia
Revisión	QA, desarrollo, administrador tecnológico y Product Owner (roles; revisión formal pendiente).
Aprobación	Pendiente de la instancia competente. Firma: no aplica, simulación académica.
Ambiente	QAS/UAT de referencia. 192.0.2.21 y 192.0.2.22 son IP reservadas para documentación, no IP operativas.

Control de versiones

Versión	Fecha	Responsable	Cambio
1.0	2026-10-25	Karol Andrea Hoyos Echandia	Primera versión; alineada con PRU-00 v1.2, PRU-01 v1.1 y Taller 2.

Convenciones de clasificación

Marca	Significado
A · Fuente	Requisito confirmado en Taller 2 o documento técnico.
B · Propuesta	Herramienta o corrección propuesta, no confirmada como desplegada.
C · Simulación	Resultado o evidencia de referencia construido para el ejercicio.
D · Pendiente	Dato, configuración o validación pendiente de equipo, DATIC o entidad.

1. Propósito y alcance

Documentar las pruebas de seguridad y su acta. El alcance cubre RNF-07 a RNF-11, S-01 a S-04 y S-06 a S-07, y AC-01 a AC-06, manteniendo trazabilidad con Taller 2, PRU-00 y PRU-01.

S-05 (restauración, RPO ≤24 h y RTO ≤8 h) se remite a PRU-06; la copia externa sigue bloqueada por dependencia de DATIC. No se declara cumplido en PRU-03.

2. Condición del entorno y método

PRU-00 v1.2 y REP-01 v1.2 indican que frontend/backend son esqueletos sin código funcional ejecutable y que no hay QAS institucional ni URL/certificados reales confirmados. Por ello, todos los resultados son C (simulación académica). No se afirma ejecución real de escaneos, CI, identidad, base de datos ni infraestructura.

Elemento	Condición / tratamiento
Fechas	Ventana de PRU-00: 28/06/2027–02/07/2027 (C).
Ambiente	QAS/UAT lógico; IP reservadas 192.0.2.21 y 192.0.2.22 solo para documentación.
Herramientas	OWASP ZAP está citado en Taller 2. Gitleaks se propone como B; no se declara ejecutado.
Datos	Cuentas, radicados, archivos y eventos sintéticos; sin secretos ni datos personales reales.
Evidencias	SIM-EV-SEC-xxx son registros simulados, no salidas reales de herramientas.
Salida	No recomendar producción sin verificación real y sin vulnerabilidades críticas/altas abiertas.

3. Criterios de aceptación y trazabilidad fuente

Referencia	Criterio de aceptación fuente
RNF-07 / S-01	Ninguna comunicación externa o integración acepta protocolos inferiores a TLS 1.2.
RNF-08 / S-02	Base, archivos y respaldos cifrados en reposo con AES-256; contraseñas con hash y sal, nunca en texto plano.
RNF-09 / S-03	Cero vulnerabilidades críticas o altas abiertas al despliegue según OWASP Top 10.
HU-03 / S-04	100 % de muestras de prueba maliciosas rechazadas; PRU-01 incluye SIM-CP-007.
RNF-10 / AC-01	100 % de la matriz de permisos coincide; accesos no autorizados denegados.
RNF-10 / AC-02	Bloqueo durante 15 minutos tras cinco intentos fallidos.

Referencia	Criterio de aceptación fuente
RNF-10 / AC-03	Aviso al minuto 28 y expiración al minuto 30 de inactividad.
RNF-10 / AC-04	Administrador tecnológico no ingresa sin segundo factor.
RNF-12 / AC-05	Caída del directorio no interrumpe sesiones activas y permite cuentas de contingencia autorizadas.
HU-01 / AC-06	Enlace de recuperación de un solo uso, con expiración a los 60 minutos.
RNF-11 / R-04 / HU-12	100 % de cambios trazables con usuario, fecha/hora, acción y valores anterior/nuevo; bitácora no editable; retención ≥5 años, sujeta a tabla documental.
S-06	Cero secretos reales en el repositorio.
S-07	100 % de los eventos de seguridad de Taller 2 §8.8 quedan registrados.
RNF-06 / S-05	Restauración ≤8 h y pérdida ≤24 h: se remite a PRU-06; copia externa pendiente.

4. Resumen de resultados del ejercicio

ID	Prueba	Estado de referencia	Evidencia
SIM-SEC-001	Cifrado de comunicaciones TLS	Cumple (simulado) · C; verificación real pendiente · D	SIM-EV-SEC-001 — matriz simulada de negociación TLS.
SIM-SEC-002	Cifrado en reposo y almacenamiento de contraseñas	Cumple (simulado) · C; verificación real pendiente · D	SIM-EV-SEC-002 — matriz de cifrado y credenciales sintéticas.
SIM-SEC-003	Análisis de vulnerabilidades web	Cumple tras repetición simulada · C; análisis real bloqueado · D	SIM-EV-SEC-003A (inicial) y SIM-EV-SEC-003B (repetición). Defecto SIM-SEC-DEF-001.
SIM-SEC-004	Rechazo de muestra de prueba EICAR	Cumple (simulado) · C; prueba real con ClamAV pendiente · D	SIM-EV-SEC-004 — registro simulado de intentos y rechazos.
SIM-SEC-005	Autorización por rol y validación en servidor	Cumple (simulado) · C; validación técnica real pendiente · D	SIM-EV-SEC-005 — matriz y trazas simuladas; referencia SIM-EV-042.
SIM-SEC-006	Bloqueo tras intentos fallidos	Cumple (simulado) · C; configuración real pendiente · D	SIM-EV-SEC-006 — secuencia de fallos y bloqueo; referencia SIM-CP-002.
SIM-SEC-007	Aviso y expiración de sesión por inactividad	Cumple (simulado) · C; validación técnica real pendiente · D	SIM-EV-SEC-007 — línea de tiempo de sesión; referencia SIM-CP-043.
SIM-SEC-008	Segundo factor para administrador tecnológico	Cumple (simulado) · C; integración real pendiente · D	SIM-EV-SEC-008 — trazas de autenticación simuladas; referencia SIM-CP-044.
SIM-SEC-009	Caída del directorio y cuenta de contingencia	Cumple (simulado) · C; integración real pendiente · D	SIM-EV-SEC-009 — secuencia de contingencia; referencia SIM-CP-029.
SIM-SEC-010	Enlace de recuperación de un solo uso	Cumple (simulado) · C; validación real pendiente · D	SIM-EV-SEC-010 — resultados simulados de recuperación; referencia SIM-CP-003.
SIM-SEC-011	Integridad, campos y retención de la bitácora	Parcial (simulado) · C/D por validación documental pendiente	SIM-EV-SEC-011 — muestra de 30 eventos y matriz de permisos de bitácora.
SIM-SEC-012	Búsqueda de secretos en el repositorio	Cumple (simulado) · C; escaneo real de CI pendiente · D	SIM-EV-SEC-012 — inventario de archivos y resultado de referencia simulado.
SIM-SEC-013	Cobertura de eventos de seguridad y alertas	Cumple (simulado) · C; integración y retención real pendientes · D	SIM-EV-SEC-013 — matriz de 28 eventos y tiempo de alerta simulado.
S-05 / RNF-06	Restauración y copia externa	Bloqueado / fuera de alcance PRU-03 · D	PRU-06; referencia SIM-CP-028

Lectura global: los resultados son simulados, no una certificación técnica. RNF-11 queda parcial por validación documental de retención. S-05 permanece bloqueado en PRU-06. La verificación real de infraestructura y aplicación sigue pendiente.

SIM-SEC-001 — Cifrado de comunicaciones TLS

Campo	Contenido
Fecha de referencia	2027-06-28 (C)
Trazabilidad exacta	A — Taller 2, Tabla 24 RNF-07; Tabla 59 S-01; §8.4. PRU-00 §8.
Objetivo	Verificar que ninguna comunicación externa ni de integración acepte protocolos inferiores a TLS 1.2.
Procedimiento y datos	C — Matriz de seis destinos de referencia: portal y cinco interfaces IF-01 a IF-05. Revisar negociación simulada con TLS 1.0/1.1 y TLS 1.2/1.3.
Resultado esperado	A — 0 comunicaciones aceptan protocolos inferiores a TLS 1.2.
Resultado obtenido	C — 6/6 destinos de referencia aceptan TLS 1.2 o superior y rechazan TLS 1.0/1.1. No se reportan protocolos obsoletos aceptados.
Estado	Cumple (simulado) · C; verificación real pendiente · D
Evidencia	SIM-EV-SEC-001 — matriz simulada de negociación TLS.
Observaciones / límites	URL, certificados y configuración reales no están confirmados; no se ejecutó un escaneo de red real.
Responsable por rol	QA registra; administrador tecnológico y desarrollo apoyan la validación técnica cuando exista ambiente; Product Owner revisa el resultado funcional.
Aprobación	Pendiente de validación formal. Firma: no aplica, simulación académica.

SIM-SEC-002 — Cifrado en reposo y almacenamiento de contraseñas

Campo	Contenido
Fecha de referencia	2027-06-28 (C)
Trazabilidad exacta	A — Taller 2, Tabla 24 RNF-08; Tabla 59 S-02; §§8.3, 8.5 y 8.6.
Objetivo	Verificar AES-256 en base de datos, archivos y respaldos, y hash con sal para contraseñas.
Procedimiento y datos	C — Revisar matriz de cuatro componentes (base, archivos, respaldo local y externo) y diez usuarios sintéticos; comprobar separación de claves y ausencia de texto plano.
Resultado esperado	A — Base, archivos y respaldos cifrados con AES-256; contraseñas con hash y sal; claves separadas de los datos.
Resultado obtenido	C — La matriz simulada registra AES-256 en 4/4 componentes y hash con sal en 10/10 registros; no aparece texto plano. La configuración efectiva queda por confirmar.
Estado	Cumple (simulado) · C; verificación real pendiente · D
Evidencia	SIM-EV-SEC-002 — matriz de cifrado y credenciales sintéticas.
Observaciones / límites	El Taller 2 no fija un algoritmo específico para el hash. No se afirma haber inspeccionado una base real ni el gestor de claves.
Responsable por rol	QA registra; administrador tecnológico y desarrollo apoyan la validación técnica cuando exista ambiente; Product Owner revisa el resultado funcional.
Aprobación	Pendiente de validación formal. Firma: no aplica, simulación académica.

SIM-SEC-003 — Análisis de vulnerabilidades web

Campo	Contenido
Fecha de referencia	2027-06-29 (C)
Trazabilidad exacta	A — Taller 2, RNF-09; Tablas 57 y 59 S-03; §8.7; E-10. PRU-00 §8.
Objetivo	Comprobar que no queden vulnerabilidades críticas ni altas abiertas según el enfoque OWASP Top 10.
Procedimiento y datos	B/C — OWASP ZAP es la herramienta de referencia del Taller 2. Simular análisis, clasificación, corrección y repetición; no hay URL productiva.
Resultado esperado	A — Cero vulnerabilidades críticas o altas abiertas al despliegue.
Resultado obtenido	C — Primera corrida simulada: 0 críticas, 0 altas y una observación media por CSP en modo de solo reporte. Tras proponer modo de cumplimiento (B), repetición simulada: 0 críticas, 0 altas y 0 hallazgos medios abiertos.
Estado	Cumple tras repetición simulada · C; análisis real bloqueado · D
Evidencia	SIM-EV-SEC-003A (inicial) y SIM-EV-SEC-003B (repetición). Defecto SIM-SEC-DEF-001.
Observaciones / límites	Resultados simulados, no salida real de OWASP ZAP. PRU-00/REP-01 indican que frontend y backend no tienen código funcional ejecutable.
Responsable por rol	QA registra; administrador tecnológico y desarrollo apoyan la validación técnica cuando exista ambiente; Product Owner revisa el resultado funcional.
Aprobación	Pendiente de validación formal. Firma: no aplica, simulación académica.

SIM-SEC-004 — Rechazo de muestra de prueba EICAR

Campo	Contenido
Fecha de referencia	2027-06-29 (C)
Trazabilidad exacta	A — Taller 2, HU-03; Tabla 59 S-04; Tabla 57; PRU-01 SIM-CP-007.
Objetivo	Verificar que el 100 % de las muestras de prueba maliciosas se rechace al cargar.
Procedimiento y datos	C — SIM-EICAR-001 como identificador de referencia; cinco intentos simulados en un flujo aislado. No se adjunta ni ejecuta una muestra real.
Resultado esperado	A — 100 % de las muestras de prueba maliciosas rechazadas.
Resultado obtenido	C — 5/5 intentos simulados fueron rechazados; ninguna muestra quedó asociada a una solicitud. Coincide con el resultado funcional de referencia SIM-CP-007.
Estado	Cumple (simulado) · C; prueba real con ClamAV pendiente · D
Evidencia	SIM-EV-SEC-004 — registro simulado de intentos y rechazos.
Observaciones / límites	ClamAV tiene una sola instancia según ARQ-01 §11; su comportamiento bajo carga se observa en PRU-05.
Responsable por rol	QA registra; administrador tecnológico y desarrollo apoyan la validación técnica cuando exista ambiente; Product Owner revisa el resultado funcional.
Aprobación	Pendiente de validación formal. Firma: no aplica, simulación académica.

SIM-SEC-005 — Autorización por rol y validación en servidor

Campo	Contenido
Fecha de referencia	2027-06-29 (C)
Trazabilidad exacta	A — Taller 2, Tablas 55/56 AC-01 y RNF-10; PRU-01 SIM-CP-042.
Objetivo	Verificar que funciones y datos correspondan al rol y que el servidor deniegue accesos no autorizados.
Procedimiento y datos	C — Cinco roles y 18 funciones: matriz de 90 combinaciones de SIM-CP-042. Se agregan doce intentos de API simulados para solicitudes ajenas y funciones reservadas.
Resultado esperado	A — 100 % de la matriz coincide con la definición; accesos no autorizados devuelven error de autorización.
Resultado obtenido	C — Las 90 combinaciones conservan el resultado funcional de PRU-01; 12/12 intentos adicionales fueron denegados en trazas simuladas.
Estado	Cumple (simulado) · C; validación técnica real pendiente · D
Evidencia	SIM-EV-SEC-005 — matriz y trazas simuladas; referencia SIM-EV-042.
Observaciones / límites	No se atribuyen respuestas reales de API al repositorio actual. Se conserva la separación de funciones entre coordinador funcional y administrador tecnológico.
Responsable por rol	QA registra; administrador tecnológico y desarrollo apoyan la validación técnica cuando exista ambiente; Product Owner revisa el resultado funcional.
Aprobación	Pendiente de validación formal. Firma: no aplica, simulación académica.

SIM-SEC-006 — Bloqueo tras intentos fallidos

Campo	Contenido
Fecha de referencia	2027-06-30 (C)
Trazabilidad exacta	A — Taller 2, Tabla 56 AC-02; RNF-10; Tabla 61; PRU-01 SIM-CP-002.
Objetivo	Comprobar el bloqueo de la cuenta por 15 minutos después de cinco intentos fallidos.
Procedimiento y datos	C — Cuenta sintética SIM-qa-solicitante02@example.org; cinco fallos consecutivos, un intento durante el bloqueo y registro de auditoría.
Resultado esperado	A — Bloqueo de 15 minutos tras cinco intentos fallidos.
Resultado obtenido	C — Tras el quinto fallo, la cuenta quedó bloqueada por 15 minutos en el escenario; el intento adicional fue denegado y el evento quedó registrado.
Estado	Cumple (simulado) · C; configuración real pendiente · D
Evidencia	SIM-EV-SEC-006 — secuencia de fallos y bloqueo; referencia SIM-CP-002.
Observaciones / límites	No se incluyen contraseñas, tokens ni datos personales reales.
Responsable por rol	QA registra; administrador tecnológico y desarrollo apoyan la validación técnica cuando exista ambiente; Product Owner revisa el resultado funcional.
Aprobación	Pendiente de validación formal. Firma: no aplica, simulación académica.

SIM-SEC-007 — Aviso y expiración de sesión por inactividad

Campo	Contenido
Fecha de referencia	2027-06-30 (C)
Trazabilidad exacta	A — Taller 2, Tabla 56 AC-03; RNF-10; PRU-01 SIM-CP-043.
Objetivo	Verificar aviso al minuto 28 y expiración de sesión al minuto 30 de inactividad.
Procedimiento y datos	C — Una sesión sintética con marcas de tiempo simuladas en los minutos 0, 28 y 30.
Resultado esperado	A — Aviso a los 28 minutos y cierre de sesión a los 30 minutos de inactividad.
Resultado obtenido	C — El aviso apareció al minuto 28 y la sesión se cerró al minuto 30; el cierre quedó registrado en la bitácora simulada.
Estado	Cumple (simulado) · C; validación técnica real pendiente · D
Evidencia	SIM-EV-SEC-007 — línea de tiempo de sesión; referencia SIM-CP-043.
Observaciones / límites	La prueba debe repetirse sobre el proveedor de identidad y la aplicación desplegados.
Responsable por rol	QA registra; administrador tecnológico y desarrollo apoyan la validación técnica cuando exista ambiente; Product Owner revisa el resultado funcional.
Aprobación	Pendiente de validación formal. Firma: no aplica, simulación académica.

SIM-SEC-008 — Segundo factor para administrador tecnológico

Campo	Contenido
Fecha de referencia	2027-06-30 (C)
Trazabilidad exacta	A — Taller 2, Tabla 56 AC-04; RNF-10; PRU-01 SIM-CP-044.
Objetivo	Confirmar que el administrador tecnológico no pueda ingresar sin segundo factor.
Procedimiento y datos	C — Dos intentos simulados: solo contraseña y contraseña más segundo factor válido; registrar ambos resultados.
Resultado esperado	A — El administrador tecnológico no ingresa sin segundo factor.
Resultado obtenido	C — El intento sin segundo factor fue denegado y el intento con segundo factor válido fue permitido en el escenario. Ambos eventos quedaron registrados.
Estado	Cumple (simulado) · C; integración real pendiente · D
Evidencia	SIM-EV-SEC-008 — trazas de autenticación simuladas; referencia SIM-CP-044.
Observaciones / límites	No se incluyen códigos MFA reales. La integración con identidad institucional debe verificarse en el ambiente asignado.
Responsable por rol	QA registra; administrador tecnológico y desarrollo apoyan la validación técnica cuando exista ambiente; Product Owner revisa el resultado funcional.
Aprobación	Pendiente de validación formal. Firma: no aplica, simulación académica.

SIM-SEC-009 — Caída del directorio y cuenta de contingencia

Campo	Contenido
Fecha de referencia	2027-07-01 (C)
Trazabilidad exacta	A — Taller 2, Tabla 56 AC-05; RNF-12; A-13; PRU-01 SIM-CP-029.
Objetivo	Comprobar continuidad de sesiones y acceso autorizado con cuenta de contingencia ante una caída del directorio.
Procedimiento y datos	C — Simular caída del directorio con tres sesiones activas y una cuenta de contingencia; exigir segundo factor, registrar activación y desactivar al recuperar el directorio.
Resultado esperado	A — Las sesiones activas no se interrumpen y la cuenta de contingencia permite acceso autorizado; la activación queda auditada.
Resultado obtenido	C — 3/3 sesiones permanecieron activas; un ingreso de contingencia fue permitido tras segundo factor; activación registrada y cuenta desactivada en la recuperación simulada.
Estado	Cumple (simulado) · C; integración real pendiente · D
Evidencia	SIM-EV-SEC-009 — secuencia de contingencia; referencia SIM-CP-029.
Observaciones / límites	La prueba de integración completa corresponde a PRU-01/RNF-12; aquí se amplía la trazabilidad de seguridad.
Responsable por rol	QA registra; administrador tecnológico y desarrollo apoyan la validación técnica cuando exista ambiente; Product Owner revisa el resultado funcional.
Aprobación	Pendiente de validación formal. Firma: no aplica, simulación académica.

SIM-SEC-010 — Enlace de recuperación de un solo uso

Campo	Contenido
Fecha de referencia	2027-07-01 (C)
Trazabilidad exacta	A — Taller 2, Tabla 56 AC-06; HU-01; RNF-10; PRU-01 SIM-CP-003.
Objetivo	Verificar que el enlace de recuperación solo se use una vez y expire a los 60 minutos.
Procedimiento y datos	C — Enlace recién emitido, segundo intento con el mismo enlace y enlace de 61 minutos; buzón example.org simulado.
Resultado esperado	A — Enlace de un solo uso y expiración a los 60 minutos.
Resultado obtenido	C — El primer uso fue aceptado; el segundo uso y el enlace de 61 minutos fueron rechazados.
Estado	Cumple (simulado) · C; validación real pendiente · D
Evidencia	SIM-EV-SEC-010 — resultados simulados de recuperación; referencia SIM-CP-003.
Observaciones / límites	Enlaces y tokens son ficticios; no se incluyen URL operativas de recuperación.
Responsable por rol	QA registra; administrador tecnológico y desarrollo apoyan la validación técnica cuando exista ambiente; Product Owner revisa el resultado funcional.
Aprobación	Pendiente de validación formal. Firma: no aplica, simulación académica.

SIM-SEC-011 — Integridad, campos y retención de la bitácora

Campo	Contenido
Fecha de referencia	2027-07-01 (C)
Trazabilidad exacta	A — Taller 2, RNF-11; Tabla 59 S-07; Tabla 61; R-04; HU-12; PRU-01 SIM-CP-018.
Objetivo	Comprobar trazabilidad de cambios, bitácora no editable y política de conservación.
Procedimiento y datos	C — Revisar 30 eventos sintéticos de cambios de estado, datos, archivos, roles y consultas autorizadas; intentar editar/borrar con rol funcional y revisar retención.
Resultado esperado	A — 100 % de operaciones trazables con usuario, fecha/hora, acción y valores anterior/nuevo; bitácora no editable; conservación ≥5 años sujeta a tabla documental.
Resultado obtenido	C — 30/30 eventos contenían los campos definidos; edición y borrado fueron denegados en el escenario. La política de referencia indica cinco años, pero la tabla documental definitiva sigue pendiente.
Estado	Parcial (simulado) · C/D por validación documental pendiente
Evidencia	SIM-EV-SEC-011 — muestra de 30 eventos y matriz de permisos de bitácora.
Observaciones / límites	La retención técnica de registros de seguridad se propone por 12 meses (Taller 2 §8.8) y requiere validación; no confundirla con la bitácora funcional ≥5 años.
Responsable por rol	QA registra; administrador tecnológico y desarrollo apoyan la validación técnica cuando exista ambiente; Product Owner revisa el resultado funcional.
Aprobación	Pendiente de validación formal. Firma: no aplica, simulación académica.

SIM-SEC-012 — Búsqueda de secretos en el repositorio

Campo	Contenido
Fecha de referencia	2027-07-02 (C)
Trazabilidad exacta	A — Taller 2 §8.5 y Tabla 59 S-06; REP-01 §§2–3; PRU-00 §8.
Objetivo	Verificar que el repositorio no contenga contraseñas, claves API, certificados privados ni archivos .env reales.
Procedimiento y datos	B/C — Revisar .env.example con valores ficticios y reglas de exclusión. Gitleaks se propone como herramienta (B); no se declara ejecutado.
Resultado esperado	A — Cero secretos reales en el repositorio.
Resultado obtenido	C — Resultado simulado: cero secretos reales confirmados; los valores de ejemplo se clasifican como placeholders. No se presenta salida real de escáner ni ejecución de CI.
Estado	Cumple (simulado) · C; escaneo real de CI pendiente · D
Evidencia	SIM-EV-SEC-012 — inventario de archivos y resultado de referencia simulado.
Observaciones / límites	REP-01 describe .env.example como ficticio y .gitignore como exclusión de secretos. No se incluyen valores operativos.
Responsable por rol	QA registra; administrador tecnológico y desarrollo apoyan la validación técnica cuando exista ambiente; Product Owner revisa el resultado funcional.
Aprobación	Pendiente de validación formal. Firma: no aplica, simulación académica.

SIM-SEC-013 — Cobertura de eventos de seguridad y alertas

Campo	Contenido
Fecha de referencia	2027-07-02 (C)
Trazabilidad exacta	A — Taller 2, Tabla 59 S-07; §8.8; Tabla 61; HU-21; RNF-11.
Objetivo	Comprobar que todos los tipos de eventos de seguridad queden registrados y que las alertas lleguen en ≤5 minutos.
Procedimiento y datos	C — 28 eventos en siete categorías: autenticaciones exitosas/fallidas, bloqueos, accesos denegados, cambios de rol, activación de contingencia, cambios de configuración y errores de integración.
Resultado esperado	A — 100 % de los eventos de §8.8 registrados; alertas al administrador en ≤5 minutos.
Resultado obtenido	C — 28/28 eventos quedaron registrados; evidencia para 7/7 categorías; retraso máximo de alerta simulado de 2 min 18 s. Sin datos personales ni secretos en la muestra.
Estado	Cumple (simulado) · C; integración y retención real pendientes · D
Evidencia	SIM-EV-SEC-013 — matriz de 28 eventos y tiempo de alerta simulado.
Observaciones / límites	Taller 2 propone 12 meses para registros técnicos de seguridad (SG-01), pendiente de validación institucional. No se afirma que Loki/Prometheus/Grafana estén operativos.
Responsable por rol	QA registra; administrador tecnológico y desarrollo apoyan la validación técnica cuando exista ambiente; Product Owner revisa el resultado funcional.
Aprobación	Pendiente de validación formal. Firma: no aplica, simulación académica.

5. Registro de defecto y repetición

Campo	Registro
ID	SIM-SEC-DEF-001
Caso	SIM-SEC-003 — análisis de vulnerabilidades web.
Severidad	Media (C: clasificación de referencia simulada).
Descripción	Primera corrida simulada: política CSP en modo de solo reporte en un destino de referencia.
Causa probable	B/C — Política de cabeceras aún no aplicada de forma obligatoria en el destino de referencia; hipótesis del ejercicio.
Acción propuesta	B — Aplicar CSP en modo de cumplimiento y revisar HSTS, X-Content-Type-Options y CORS restrictivo según Taller 2 §8.4.
Repetición	C — En la repetición simulada no quedan hallazgos críticos, altos ni medios abiertos.
Cierre	C/D — Cerrado solo en la secuencia simulada; corrección y escaneo reales pendientes.

No se afirma que se haya modificado código o configuración real. La secuencia ilustra el registro, corrección y repetición.

6. Matriz de trazabilidad final

Referencia	Caso	Estado	Nota
RNF-07 / S-01	SIM-SEC-001	Cumple simulado · C	TLS ≥1.2 en 6 destinos de referencia; URL/certificados reales D.
RNF-08 / S-02	SIM-SEC-002	Cumple simulado · C	AES-256 y hash/sal en matriz; configuración real D.
RNF-09 / S-03 / E-10	SIM-SEC-003	Cumple tras repetición simulada · C	0 críticas/altas abiertas en escenario; escaneo real bloqueado D.
HU-03 / S-04	SIM-SEC-004; SIM-CP-007	Cumple simulado · C	5/5 intentos de referencia rechazados; muestra real no adjunta.
RNF-10 / AC-01	SIM-SEC-005; SIM-CP-042	Cumple simulado · C	90 combinaciones heredadas y 12 denegaciones de referencia.
RNF-10 / AC-02	SIM-SEC-006; SIM-CP-002	Cumple simulado · C	Bloqueo 15 min tras 5 fallos.
RNF-10 / AC-03	SIM-SEC-007; SIM-CP-043	Cumple simulado · C	Aviso minuto 28 y expiración minuto 30.
RNF-10 / AC-04	SIM-SEC-008; SIM-CP-044	Cumple simulado · C	Ingreso administrativo sin segundo factor denegado.
RNF-12 / AC-05	SIM-SEC-009; SIM-CP-029	Cumple simulado · C	Sesiones activas y contingencia con auditoría.
HU-01 / AC-06	SIM-SEC-010; SIM-CP-003	Cumple simulado · C	Enlace de un uso y expiración a 60 min.
RNF-11 / R-04 / HU-12	SIM-SEC-011; SIM-CP-018	Parcial · C/D	30/30 eventos completos; tabla de retención definitiva pendiente.
S-06	SIM-SEC-012	Cumple simulado · C; CI real D	0 secretos confirmados en escenario; escaneo CI pendiente.
S-07	SIM-SEC-013	Cumple simulado · C; monitoreo real D	28/28 eventos registrados; alerta máxima 2 min 18 s.
RNF-06 / S-05	PRU-06; SIM-CP-028	Bloqueado · D	Copia externa no verificada; no se declara cumplido en PRU-03.

7. Pendientes para validación real

Disponer de una versión ejecutable e identificada de frontend/backend.

Asignar QAS institucional y registrar URL, certificados, endpoints y versiones reales; las IP actuales son documentales.

Ejecutar y adjuntar salidas reales de TLS, OWASP ZAP, dependencias/imágenes y escaneo de secretos.

Verificar cifrado efectivo de base, archivos y respaldos; almacenamiento de contraseñas y separación de claves.

Ejecutar permisos y sesiones en servidor/proveedor de identidad.

Confirmar la tabla de retención documental para bitácora funcional y aprobar la propuesta de 12 meses para registros técnicos.

Mantener S-05/RNF-06 bloqueado hasta completar PRU-06, incluida la copia externa.

No recomendar producción con base exclusiva en resultados simulados; la aceptación de E-10 requiere los informes/actas y la instancia competente.

8. Referencias documentales

Guía de Despliegue de Sistemas de Información DATIC, MAGT04.04.01.P004.G001, §§4.1 y 4.2.

Taller 2 final: Tabla 23 (HU-01/HU-03/HU-12/HU-21); Tabla 24 (RNF-07 a RNF-12); Tablas 55, 56, 57, 59 y 61; §§8.4–8.8; Tabla 74 (R-04).

PRU-00 Plan de Pruebas v1.2: §7, §8, §9 y §§12–15.

PRU-01 v1.1: SIM-CP-002, SIM-CP-003, SIM-CP-007, SIM-CP-018, SIM-CP-029, SIM-CP-042, SIM-CP-043 y SIM-CP-044.

DEC-01 v1.2, §§6.2–6.3 y 8 (IP, calendario y simulaciones).

ARQ-01 v1.1, §11 (ClamAV y observabilidad).

REP-01 v1.2, §§2–4 (esqueleto frontend/backend, .env.example, exclusión de secretos y convención documental).

9. Acta de la sesión de seguridad

Campo	Contenido
Código de acta	PRU-03-AT-01 — Sesión de revisión de seguridad.
Fecha de referencia	2027-07-02 (C).
Objetivo	Revisar resultados simulados, documentar desviaciones y definir condiciones para verificación real.
Participantes por rol	QA; administrador tecnológico; desarrollo; Product Owner como rol de revisión. No se atribuyen nombres ni firmas.
Temas revisados	TLS; cifrado en reposo y contraseñas; vulnerabilidades; EICAR; autorización; bloqueo; sesión; MFA; contingencia; recuperación; bitácora; secretos; eventos y alertas.
Conclusiones	El escenario no deja vulnerabilidades críticas/altas abiertas tras la repetición simulada. EICAR y controles de acceso muestran resultados simulados dentro de criterio. RNF-11 queda parcial por validación documental; S-05 sigue en PRU-06. La seguridad real no está certificada.
Acuerdos y acciones	1) Ejecutar escaneos reales con código y QAS. 2) Verificar TLS, cifrado, MFA y permisos. 3) Confirmar retención institucional. 4) Completar PRU-06 para S-05. 5) Mantener el informe como simulación hasta aportar evidencia real.
Estado del acta	Registro de referencia; revisión y aprobación formal pendientes.
Firma	No aplica, simulación académica.